GRC

RISK AND CONTROL ADVISORY

Annual conclusion 2027

Input to the ICT risk management framework review report (RTS (EU) 2024/1774 Art. 27)

PREPARED FOR

2LoD CISO Office (ICT risk control function)

CONFIDENTIAL PLAN V1

REFERENCE AP-2027-001-ANNUAL	ENGAGEMENT AP-2027-001 2027 Security NFR Controls Testing Plan — Tier 1 & Tier 2 ICT assets	VERSION Plan v1
PREPARED BY PM (2LoD)	REVIEWED BY CISO (2LoD)	REPORT DATE 2028-01-28
ASSESSMENT PERIOD 1 Jan – 31 Dec 2027	FRAMEWORKS DORA Art. 6(4), 6(5), 8(1), 24(6), RTS (EU) 2024/1774 Art. 2(2)(c), 4–5, 27	DISTRIBUTION ICT Risk Committee

Executive Summary

This is the annual conclusion of AP-2027-001, 2027 Security NFR Controls Testing Plan — Tier 1 & Tier 2 ICT assets, for 1 Jan – 31 Dec 2027. It is an input to the ICT risk management framework review report (DORA Art. 6(5); RTS (EU) 2024/1774 Art. 27).

Tier 1: on the 35 test(s) performed, the controls tested are effective except for NFR-04 (Access management & recertification), concluded not effective under the deviation rule.

Tier 2: on the 21 test(s) performed, the controls tested are effective. NFR-11 (Network security & exposure) had one deviation, and its sample was extended.

Testing is incomplete: 56 of 64 planned tests were performed and 54 signed off by QA. The conclusion is limited to the tests performed.

FINDINGS BY SEVERITY

0	2	1	0	0
CRITICAL	HIGH	MEDIUM	LOW	INFO

KEY MESSAGES

- Tier 1: 72 of 80 items attested (90%), 72 with data quality accepted.
- Tier 2: 214 of 240 items attested (89.17%), 214 with data quality accepted.
- 56 of 64 planned tests performed, 54 signed off by QA.
- 1 attribute and stratum pair(s) concluded not effective.
- 3 finding(s) raised, 3 open, 0 overdue.

Contents

Executive Summary 2
1 Population and coverage 4
2 Tests performed 4
3 Results by attribute and stratum 4
4 Findings 5
5 Conclusion 5
6 Findings 7
6.1 AF-2026-001 NFR-04 Access management & recertification not met on T1-022 Example Card authorisation 02 7
6.2 AF-2026-003 NFR-04 Access management & recertification not met on T1-057 Example Branch teller 03 7
6.3 AF-2026-002 NFR-11 Network security & exposure not met on T2-098 Example Contact centre 09 7
A Test attributes 8
B Regulatory basis 8
Limitations and Basis of Reporting 9

1 Population and coverage

The population is the 320 item(s) in scope, frozen on 6 Nov 2026. The year's objective is every item of every stratum attested by its 1LoD owner and its data quality accepted by 2LoD.

COVERAGE ACHIEVED

Stratum	N	Attested	DQ accepted
Tier 1	80	72 (90%)	72 (90%)
Tier 2	240	214 (89.17%)	214 (89.17%)

2 Tests performed

2LoD planned 64 test(s), opened 56 and signed off 54. Samples were sized by attribute sampling at each stratum's confidence and tolerable deviation rate, with a coverage floor and risk-based top-ups, and drawn each quarter from a seed recorded when the population was frozen, so the draws can be re-performed.

BY QUARTER

Quarter	Planned	Opened	QA signed off	Effective	Partially effective	Ineffective
Q1	19	17	17	16	1	0
Q2	20	18	18	17	1	0
Q3	18	16	16	15	1	0
Q4	7	5	3	3	0	0

BY STRATUM

Stratum	N	Statistical sample	Planned tests	Tests performed
Tier 1	80	35	39	35
Tier 2	240	21	25	21

3 Results by attribute and stratum

The deviation rule is applied per attribute and stratum, cumulatively over the year: no deviations is effective; 1 extends the sample; 2 or more is not effective, a thematic finding. Rows with no tests are not listed; Appendix A names each attribute's domain.

CONCLUSIONS

Attribute	Stratum	Tested	Deviations	Conclusion	Risk raised
NFR-01	T1	35	0	No deviations / effective	
NFR-01	T2	19	0	No deviations / effective	
NFR-02	T1	35	0	No deviations / effective	
NFR-02	T2	19	0	No deviations / effective	
NFR-03	T1	35	0	No deviations / effective	
NFR-03	T2	19	0	No deviations / effective	
NFR-04	T1	35	2	Not effective – thematic finding	AP-2027-001-NFR-04-T1
NFR-04	T2	19	0	No deviations / effective	
NFR-05	T1	35	0	No deviations / effective	

NFR-05	T2	19	0	No deviations / effective
NFR-06	T1	35	0	No deviations / effective
NFR-06	T2	19	0	No deviations / effective
NFR-07	T1	35	0	No deviations / effective
NFR-07	T2	19	0	No deviations / effective
NFR-08	T1	35	0	No deviations / effective
NFR-08	T2	19	0	No deviations / effective
NFR-09	T1	35	0	No deviations / effective
NFR-09	T2	19	0	No deviations / effective
NFR-10	T1	35	0	No deviations / effective
NFR-10	T2	19	0	No deviations / effective
NFR-11	T1	35	0	No deviations / effective
NFR-11	T2	19	1	1 deviation – extend sample
NFR-12	T1	35	0	No deviations / effective
NFR-12	T2	19	0	No deviations / effective
NFR-13	T1	35	0	No deviations / effective
NFR-13	T2	19	0	No deviations / effective
NFR-14	T1	35	0	No deviations / effective
NFR-14	T2	19	0	No deviations / effective
NFR-15	T1	35	0	No deviations / effective
NFR-15	T2	19	0	No deviations / effective
NFR-16	T1	35	0	No deviations / effective
NFR-16	T2	19	0	No deviations / effective

4 Findings

3 finding(s) were raised in Audit Findings from the year's fails: 3 open, 0 overdue. Each is set out below as Audit Findings holds it.

BY SEVERITY

Severity	Raised	Open	Overdue	Closed or accepted
Critical	0	0	0	0
High	2	2	0	0
Medium	1	1	0	0
Low	0	0	0	0

5 Conclusion

Tier 1: on the 35 test(s) performed, the controls tested are effective except for NFR-04 (Access management & recertification), concluded not effective under the deviation rule.

Tier 2: on the 21 test(s) performed, the controls tested are effective. NFR-11 (Network security & exposure) had one deviation, and its sample was extended.

Testing is incomplete: 56 of 64 planned tests were performed and 54 signed off by QA. The conclusion is limited to the tests performed.

6 Findings

Ref	Finding	Severity	Control
AF-2026-001	NFR-04 Access management & recertification not met on T1-022 Example Card authorisation 02	HIGH	AC-2, AC-6
AF-2026-003	NFR-04 Access management & recertification not met on T1-057 Example Branch teller 03	HIGH	AC-2, AC-6
AF-2026-002	NFR-11 Network security & exposure not met on T2-098 Example Contact centre 09	MEDIUM	SC-7

6.1 AF-2026-001 NFR-04 Access management & recertification not met on T1-022 Example Card authorisation 02

HIGH AC-2, AC-6 OPEN

OBSERVATION

Evidence received and walked through with the asset owner.

note on NFR-04

6.2 AF-2026-003 NFR-04 Access management & recertification not met on T1-057 Example Branch teller 03

HIGH AC-2, AC-6 OPEN

OBSERVATION

Evidence received and walked through with the asset owner.

note on NFR-04

6.3 AF-2026-002 NFR-11 Network security & exposure not met on T2-098 Example Contact centre 09

MEDIUM SC-7 OPEN

OBSERVATION

Evidence received and walked through with the asset owner.

note on NFR-11

A Test attributes

What 2LoD tested on every selected item. The full requirement, procedure, evidence and pass criteria are in the plan's export.

Ref	Domain	Method	800-53
NFR-01	Asset identification & classification	Inspection	CM-8, RA-2
NFR-02	Security requirements specified & approved	Inspection	SA-4, PL-2
NFR-03	Identity & authentication	Inspection	IA-2, IA-5
NFR-04	Access management & recertification	Re-performance	AC-2, AC-6
NFR-05	Privileged access	Inspection	AC-2, AC-6
NFR-06	Encryption at rest & key management	Inspection	SC-28, SC-12
NFR-07	Encryption in transit	Inspection	SC-8, SC-13
NFR-08	Logging & security monitoring	Inspection	AU-2, AU-6, SI-4
NFR-09	Vulnerability & patch management	Inspection	RA-5, SI-2
NFR-10	Secure configuration & hardening	Inspection	CM-6, CM-7
NFR-11	Network security & exposure	Inspection	SC-7
NFR-12	Security testing ≤ 12 months	Inspection	CA-8, SA-11
NFR-13	Backup, recovery & RTO/RPO	Inspection	CP-9, CP-10, CP-4
NFR-14	Change management	Inspection	CM-3, CM-4
NFR-15	Third-party, legacy & end-of-support	Inspection	SA-22, SA-9
NFR-16	Exceptions & risk acceptance	Inspection	CA-5, RA-7

B Regulatory basis

Reference	Requirement	How the plan meets it
DORA Art. 6(4)	Assign the management and oversight of ICT risk to a control function with an appropriate level of independence, segregated from the first line and from internal audit.	The 2LoD CISO Office plans, tests and concludes; asset owners (1LoD) attest their own data; Internal Audit (3LoD) is informed and not part of the testing.
DORA Art. 8(1)	Identify, classify and document the ICT assets that support the business functions, and review the classification at least yearly.	Every Tier 1 and Tier 2 asset's Security NFR data is attested by its owner and data-quality reviewed by 2LoD within the year, in quarterly waves.
DORA Art. 8(4); RTS (EU) 2024/1774 Arts. 4–5	Identify all ICT assets, map those considered critical and their interdependencies, under an ICT asset management policy and procedure.	The scope population is extracted from the ICT asset inventory, reconciled to the critical or important function mapping, and frozen before the first draw.
DORA Art. 24(6)	Test the ICT systems and applications that support critical or important functions at least yearly.	Tier 1 assets support a critical or important function and are sample-tested against the Security NFRs every quarter. This complements the resilience testing programme; it does not replace it.

DORA Art. 6(5); RTS (EU) 2024/1774 Art. 27	Review the ICT risk management framework at least yearly, and report on the review to the competent authority on request.	The annual conclusion goes to the ICT Risk Committee and the management body as an input to the framework review report.

Limitations and Basis of Reporting

This report is prepared by the 2LoD CISO Office (ICT risk control function) for the ICT Risk Committee, from the records of assurance plan AP-2027-001 as they stood on 14 Jan 2028. It does not reflect changes made after that date. Coverage is measured from the attestation and data-quality review dates recorded in the plan. Testing is on samples, which gives reasonable rather than absolute assurance; results not signed off by QA are provisional. Findings are reported as Audit Findings holds them on the report date; their remediation is followed up there. The conclusion is the control function's on the tests performed. It is not an opinion on the design or operation of controls outside the plan's scope, and it does not replace the resilience testing programme or internal audit's work.